

OpenClaw 网关 — 深度审计报告

审计日期：2026-06-19 | 机器：WLY\10979 | OpenClaw v2026.6.6 范围：开机自启、自动更新、v2026.6.6 配置正确性、安全与成本。

摘要

审计发现网关**当时处于宕机/崩溃循环**，开机自启**实际失效**，且存在 机密公网泄露与 “全网可用” 的高危渠道配置。以下为发现项与处置。

#	发现	严重度	处置
1	<code>OpenClaw Gateway</code> 计划任务被置为 Disabled ，BootTrigger 不触发；重启后网关不自启	致命	重注册并启用任务（指向新路径）
2	网关崩溃循环：启动后短暂监听即退出	致命	安全模式消除崩溃源（见 4/5/6），稳定监听
3	明文 Telegram Token / 网关密码 / Google 私钥片段被推送到 公开 GitHub 仓库	致命	从公开仓库移除；建议轮换 Token
4	<code>update.checkOnStart=true</code> 启动即拉取 npm 注册表 超时 （网络/代理），拖慢/影响启动	中	安全模式关闭；建议常驻用 stable 通道
5	Agent 会话 context overflow 死循环（Qwen 上限 96000 tokens）	中	安全模式停 agent；建议 <code>/new</code> 习惯 + 自动压缩
6	<code>memory-core.dreaming=true</code> 等后台任务无人值守自动消耗 LLM 费用	中	安全模式关闭；按需开启
7	Telegram/飞书 <code>allowFrom</code> 含 <code>"*"</code> 、 <code>dmPolicy:open</code> ，配合 <code>commands.bash=true</code> → 公网 RCE/烧钱面	严重	安全模式关入站；强烈建议永久去 <code>"*"</code>
8	<code>--max-old-space-size=512</code> 对满配置（多渠道+插件+agent）可能偏低致 OOM	低	报告建议：活跃模式调高或移除
9	自定义守护脚本重写覆盖 v2026.6.6 原生 <code>daemon</code> (schtasks)，同名任务冲突隐患	低	报告建议：长期统一到原生 <code>daemon</code>

与旧手册的偏差（旧手册部分内容失实）

- LLM 实际是 **DashScope/Qwen**，非旧手册所写的 Gemini。
- 旧手册称 Telegram 为 “强白名单 only 一个 ID”，实际 `allowFrom` 含 `"*"`（全开）。
- `controlUi.allowInsecureAuth` 实际为 `false`；`tailscale.resetOnExit` 实际为 `true`。

开机自启结论

- **结论：审计时不可靠。**任务 Disabled 导致 BootTrigger 失效，重启后网关不自启，仅靠 15 分钟心跳偶发拉起且不稳定。已通过重注册+启用任务 + 安全模式稳定化修复。

自动更新结论

- v2026.6.6 自带 `openclaw update` (install=npm, channel=beta, 发现可更新 2026.6.9-beta.1) 。
- `update.auto.enabled=true` + `checkOnStart=true` 会在启动时联网检查；当前网络下**超时**。
- 自定义 `openclaw_update.ps1` (`npm update -g`) 与原生机制并存，建议以原生 `openclaw update` 为准。

验收

1. `Get-ScheduledTask "OpenClaw Gateway"` → `State=Ready` ；触发后 18789 有监听。
2. 安全模式： `auth-profiles.json` key 为空、备份存在；agent 调用因无 key 失败 → 零花费。
3. `enable-openclaw-api.ps1` 后 key 恢复、健康检查通过。
4. 公开仓库 `git grep` 无任何密钥命中。